

Vulnerability Management Policy

Owner: Transformative Leadership Lab LLC · **Applies to:** Meeting Cost Meter (Zoom App)

Contact: thomas+mcsupport@txl-lab.com · **Effective:** 1 June 2026 · **Review:** annually or on material change

Controls actually in place for a small-team operation. We do not currently engage a third-party penetration tester; that is noted honestly here, not implied otherwise.

Sources of vulnerability information

- **SAST:** GitHub CodeQL code scanning on every push/PR to `main` and weekly.
- **Dependencies:** GitHub Dependabot alerts + weekly update PRs (see `dependency-management.md`).
- **External reports:** coordinated disclosure via `SECURITY.md` / the contact above.
- **Vendor advisories:** GitHub, Railway, and Zoom security notices.

Triage & severity

Reports and findings are triaged on a simple severity scale based on exploitability and impact to user data:

- **Critical** — remote data exposure / account compromise.
- **High** — meaningful security weakness, limited preconditions.
- **Medium** — defense-in-depth gaps, limited impact.
- **Low / informational** — hardening opportunities.

Remediation targets

Targets are measured from confirmation of a valid issue:

- **Critical:** mitigate or patch within **7 days** (faster where feasible).
- **High:** within **30 days**.
- **Medium:** within **90 days**.
- **Low:** as part of normal maintenance.

If a fix cannot meet the target, a documented compensating control or mitigation is applied in the interim.

Tracking & remediation

Confirmed issues are tracked as GitHub issues/PRs and fixed through the standard SSDLC (feature branch → review → required checks → merge to protected `main` → deploy). Security fixes are prioritized ahead of feature work.

Disclosure

We acknowledge external reports and coordinate a fix and disclosure timeline with the reporter. We ask reporters not to publicly disclose before a fix is available. Where an incident affects users, see [incident-response.md](#).